الحوكمة والضوابط في زمن المخابط

Lecture 1 — Cybersecurity Governance: Foundations, Protection Architecture & Enterprise Governance

> **Security** : what helps an organization continue to exist and operate despite attempts to steal data or compromise its physical and logical assets. It is a **business management responsibility**, not merely an IT concern.

> **IT/IS** : the hardware and software that support business operations; security protects their reliable operation and supports the organization's **mission, goals and objectives**.

Q/ What are the three common methods to evaluate security ?

Method	Primary objective	How it works
Risk assessment	Identify assets, threats and vulnerabilities to calculate exposure	Evaluates impact vs likelihood; sets mitigation priorities
Vulnerability assessment	Find known software, hardware and configuration weaknesses	**Automated scanning tools** and baselining
Penetration testing	Stress-test defenses against simulated real attacks	**Trusted/ethical testers** find exploitable flaws and logic gaps

Q/ How should security controls be selected ?

- To give the **greatest protection at the lowest reasonable cost**, meeting the organization's needs, complying with laws, and backed by **evidence** (to defend actions in court and avoid fines, penalties or negligence claims).

Security is an **ongoing process**, never a finished project — technology, users, vulnerabilities and attacks keep changing.

The five pillars

Q/ What are the five pillars of information security ?

1. Confidentiality. 2. Integrity. 3. Availability. 4. Authenticity. 5. Nonrepudiation.

- The first three form the **CIA Triad**, the primary goals of information security.

> **Confidentiality** : information is disclosed only to authorized individuals or systems.

Q/ What causes unauthorized disclosure and how is it prevented ?

- Causes: deliberate attacks, human error, poor policies, misconfigured controls.
- Protections: encryption, access control, strong authentication, data classification, training.

Confidentiality concept	Meaning
Sensitivity	Potential harm from disclosure
Discretion	Controlling disclosure
Concealment / Secrecy	Hiding / preventing disclosure
Privacy	Protecting personal information
Seclusion	Storing information in a restricted location
Isolation	Keeping information separate

> **Integrity** : protects the **accuracy, correctness and reliability** of information — preventing unauthorized changes and minimizing mistakes by authorized users.

Q/ Integrity — threats, protections, concepts ?

- Threats: viruses, unauthorized access, software errors, malicious modifications, **logic bombs**, **backdoors**.
- Protections: access controls, strong authentication, intrusion detection, **hash verification**, input validation, training.
- Concepts: accuracy, truthfulness, validity, accountability, responsibility, completeness, comprehensiveness.

> **Availability** : authorized users can access information and systems **when needed**, without unacceptable interruption.

Q/ Availability — threats, protections, concepts ?

- Threats: hardware failure, software errors, environmental problems, power loss, **DoS**, communication interruptions.
- Protections: performance monitoring, access controls, firewalls, **redundant systems**, tested backups, **fault tolerance**, **BCP** (removes single points of failure).

- Concepts: **usability** (ease of use), **accessibility** (different users can interact), **timeliness** (reasonable response time).

CIA	Question
Confidentiality	**Who can see or read** the information?
Integrity	Is it **accurate, valid and unmodified**?
Availability	Can authorized users access it **on demand**?

> **DAD Triad** : the **opposite / failure state** of CIA.

DAD	Violates
Disclosure — unauthorized access	Confidentiality
Alteration — malicious or accidental change	Integrity
Destruction / DoS — damaged or inaccessible	Availability

> **Overprotection** : over-protecting confidentiality or integrity can **restrict availability**, and over-providing availability can **destroy confidentiality and integrity** — security must be balanced.

> **Authenticity** : data is **genuine** and originates from its **claimed origin**.

> **Nonrepudiation** : a subject **cannot deny** performing an action (supported by identification, authentication, authorization, auditing, accounting, digital certificates, transaction logs).

> **AAA services** : five elements that must all be implemented to avoid structural weaknesses.

Element	Definition	Mechanisms
1. Identification	Claiming an identity	Usernames, smart cards, tokens, biometric identifiers
2. Authentication	Proving the claimed identity	Passwords, PINs, OTP tokens, certificates, biometric match
3. Authorization	Granting specific permissions	RBAC, ABAC, ACLs

Element	Definition	Mechanisms
4. Auditing	Recording activity	System, access and intrusion logs
5. Accounting (Accountability)	Reviewing logs for compliance; holding subjects **legally liable**	SIEM log aggregation, compliance reviews, forensics, nonrepudiation

Order matters: **identify → authenticate → authorize → audit → account**.

Protection mechanisms

Defense in depth (layering) : multiple security controls **in series** (not in parallel), so an attack is checked by every control and the failure of one doesn't break the whole solution.

Series (layering)	Parallel
Narrow and deep	Useful in distributed computing
Failure of one control doesn't expose everything	One path failing can bypass the rest

Related terms: levels, multilevel, layers, classifications, zones, realms, compartments, silos, segmentations, lattice structures, protection rings.

Defense in breadth (diversity of defense) : using products from **different vendors** so one vulnerability can't break several layers at once.

Abstraction : grouping similar elements into **roles, classes or groups** that receive the same controls and permissions (from object-oriented programming).

Unknown environment doctrine : users don't need to know how an object works inside, only the correct inputs and outputs (like user-mode apps calling system calls → **mediated access**).

Data hiding : placing data in a logical compartment that is **invisible and unreachable** to unauthorized subjects.

Data hiding	Security through obscurity
Real protection: data is functionally unviewable and inaccessible	Relies only on **secrecy**, hoping no one finds it

Data hiding	Security through obscurity
Separate security containers	"Digital hide and seek"
e.g. multilevel systems, apps can't touch hardware directly, steganography	e.g. shipping software with a known flaw and hoping nobody notices

> **Security boundary** : the line between areas, subnets or environments with **different security requirements** (e.g. LAN vs Internet).

Q/ What are the rules for security boundaries ?

1. They exist in **physical and logical** environments — both need their own mechanisms and policy.
2. Policy must define **where control begins and ends** (logical: where communications reach your devices; physical: walls, building, campus fence — also the reach of **legal responsibility**).
3. Evaluate each boundary separately for the most **cost-effective** solution.
4. Never spend more on a countermeasure than the **value** of the protected asset.

Security governance

> **Security governance** : practices that **support, evaluate, define and direct** an organization's security efforts — ideally by a **board of directors / governance committee** (in small organizations, the CEO or CISO).

Q/ What are the key points of security governance ?

1. Closely linked with **corporate and IT governance** (keep processes running, growth, minimize downtime and loss).
2. Driven by **legislative/regulatory compliance**, industry guidelines, licensing.
3. Must be **audited and validated** periodically (harder when countries' laws conflict).
4. Security is a **business operations issue**, not only back-end IT.
5. Frameworks: **NIST SP 800-53**, **NIST SP 800-100** (government-focused, adaptable by companies).

> **Third-party governance** : external oversight required by laws, regulations, standards, contracts or licensing (outside auditors/investigators) — and also **oversight of external providers** you rely on (guards, maintenance, support, accounting), who must comply with your security stance.

Q/ How is third-party compliance verified ?

1. **On-site assessments** — firsthand view of deployed controls.
2. Auditors follow protocols like **COBIT** with a requirements checklist.
3. **Open document exchange** between the organization and the governing body.
4. Organization submits **security policies and self-assessment reports → documentation review**.

Summary of Cybersecurity Governance L1: Cybersecurity Governance: CIA, AAA & Controls. Built only from the lecture file; check the original slides for anything you're unsure about.